# 2026-05-11 — Gemini ISC2 SSCP Mock Exam (125 Questions + Score)

## **Performance Report:** 116/125 (92.8%)

Performance AnalysisDomains: Domain 1, 2 & 3

| Topic | Analysis |
|---|---|
| **Core Strengths** | • **Access Control & IAAA:** Excellent understanding of Least Privilege, Separation of Duties, and Authentication steps.<br>• **Quantitative Risk:** Perfect calculation of SLE and ALE formulas.<br>• **Physical Security:** Strong grasp of mantraps, deterrents, and environmental controls.<br>• **Data Integrity Models:** Clear understanding of Biba and Bell-LaPadula properties. |
| **Areas for Improvement** | • **Cryptography Keys:** Distinguishing between sender/recipient keys in digital signatures.<br>• **Biometric Metrics:** Reviewing the specific definitions of FAR (Type II) and FRR (Type I).<br>• **Framework Specifics:** Mastering the unique steps in NIST RMF and the phases of OCTAVE.<br>• **Regulatory Compliance:** Differentiating between US-specific (HIPAA/SOX) and international standards. |

## Full Exam Transcripts (Questions 1-125)

*This section contains a complete, non-summarized record of every question asked. Incorrect user answers are highlighted in red.*

## 1

An organization implements a policy requiring two different individuals to complete a high-value financial transaction. Which security principle is being applied?

- Least Privilege
- **Separation of Duties (Correct)**
- Job Rotation
- Implicit Deny

**Reasoning:** Separation of duties ensures that no single individual has total control over a critical process.

## 2

Which of the following represents a 'something you are' authentication factor?

- A hardware token generating an OTP
- **A retina scan (Correct)**
- A complex passphrase
- A PIN sent via SMS

**Reasoning:** Biometrics measure physical or behavioral characteristics.

## 3

During a risk assessment, an analyst determines that the Annualized Rate of Occurrence (ARO) for a flood is 0.1 and the Single Loss Expectancy (SLE) is $100,000. What is the Annualized Loss Expectancy (ALE)?

- $1,000,000
- **$10,000 (Correct)**
- $50,000
- $100,000

**Reasoning:** ALE = SLE x ARO.

## 4

Which access control model is primarily based on data labels and security clearances?

- DAC
- RBAC
- **MAC (Correct)**
- ABAC

**Reasoning:** Mandatory Access Control uses system-enforced labels and clearances.

## 5

A security administrator is reviewing logs and notices an unusual amount of failed login attempts from a single IP address. Which phase of the risk management process does this best represent?

- Risk Assessment
- **Risk Monitoring (Correct)**

- Risk Treatment
- Risk Identification

**Reasoning:** Monitoring involves the ongoing observation of systems to detect anomalies.

## 6

Which component of the CIA Triad is most directly impacted by a Distributed Denial of Service (DDoS) attack?

- Confidentiality
- Integrity
- **Availability (Correct)**
- Accountability

**Reasoning:** DDoS attacks aim to overwhelm a system so that legitimate users cannot access it.

## 7

Which risk handling strategy involves purchasing an insurance policy to cover potential losses from a cyber breach?

- Risk Avoidance
- Risk Mitigation
- **Risk Transference (Correct)**
- Risk Acceptance

**Reasoning:** Transference shifts the financial burden of the risk to a third party.

## 8

What is the primary purpose of a 'honey pot' in a network environment?

- To block malicious traffic
- **To provide a decoy system that attracts and monitors attacker activity (Correct)**
- To encrypt sensitive data
- To load balance traffic

**Reasoning:** A honey pot is a sacrificial system intended to lure attackers.

## 9

In the context of access control, what does 'Implicit Deny' mean?

- Users are granted access unless blocked
- **Access is forbidden unless a specific rule permits it (Correct)**
- Administrators must manually approve attempts
- Access is denied only if the user is blacklisted

**Reasoning:** Implicit deny ensures that any access not explicitly authorized is automatically blocked.

## 10

Which of the following is a physical access control?

- A digital certificate
- An Access Control List

- **A mantrap (Correct)**
- A security policy

**Reasoning:** A mantrap is a physical entry control consisting of two interlocking doors.

## 11

Which security model is specifically designed to prevent conflicts of interest by dynamically restricting access based on a user's previous actions?

- Bell-LaPadula Model
- Biba Integrity Model
- **Brewer-Nash (Chinese Wall) Model (Correct)**
- Clark-Wilson Model

**Reasoning:** The Brewer-Nash model prevents information flow between sets of data that would create a conflict of interest.

## 12

An organization is calculating the risk of a server failure. If the cost to replace the server is $5,000 and the lost productivity cost is $15,000, what is the Single Loss Expectancy (SLE)?

- $5,000
- $15,000
- **$20,000 (Correct)**
- $40,000

**Reasoning:** The SLE is the total cost of a single occurrence.

## 13

Which of the following is an example of a technical (logical) access control?

- Security Awareness Training
- **Encryption of data at rest (Correct)**
- Background checks
- CCTV monitoring

**Reasoning:** Encryption uses mathematical algorithms and software mechanisms to restrict access.

## 14

In a Federated Identity Management (FIdM) system, what is the role of the Identity Provider (IdP)?

- Provide actual service
- **Authenticate the user and issue security tokens (Correct)**
- Audit logs
- Gateway

**Reasoning:** The IdP is responsible for verifying the user's identity.

## 15

Which term describes a vulnerability that is unknown to the software vendor and has no

available patch?

- **Zero-day (Correct)**
- Legacy exploit
- APT
- False Positive

**Reasoning:** A zero-day is exploited before a fix is created.

## 16

What is the primary difference between a Vulnerability Assessment and a Penetration Test?

- Exploitation vs Identification
- **Search for weaknesses vs Active exploitation (Correct)**
- Internal staff vs Third parties
- Physical vs Network

**Reasoning:** Pen tests attempt to actively exploit weaknesses found.

## 17

Which of the following describes 'Residual Risk'?

- Total risk before controls
- **Risk remaining after security controls (Correct)**
- Third-party vendor risk
- Control failure risk

**Reasoning:** Residual risk is the 'leftover' risk that must be accepted or transferred.

## 18

In the Kerberos protocol, which component is responsible for issuing Ticket Granting Tickets (TGT)?

- **The Key Distribution Center (KDC) (Correct)**
- The Ticket Granting Service (TGS)
- The Client Workstation
- The Application Server

**Reasoning:** The KDC manages ticket issuance central authority.

## 19

A system administrator uses an automated tool to ensure that all servers in the data center meet a specific set of security configuration requirements. What is this process called?

- Risk Assessment
- Compliance Auditing
- **Security Baselining (Correct)**
- Vulnerability Management

**Reasoning:** Baselining establishes a minimum set of security requirements.

## 20

Which of the following access control methods is most effective at preventing 'privilege creep'

when an employee changes departments?

- DAC
- **Role-Based Access Control (RBAC) (Correct)**
- MAC
- ACL

**Reasoning:** RBAC allows administrators to easily reassign roles and permissions.

## 21

What is the primary goal of Continuous Monitoring (ConMon)?

- Yearly audit
- **Maintain ongoing awareness of security state (Correct)**
- Replace firewalls
- Delete suspicious files

**Reasoning:** ConMon provides real-time data on the security environment.

## 22

In the 'Plan-Do-Check-Act' (PDCA) cycle, which activity corresponds to the 'Check' phase?

- Implementing controls
- Defining scope
- **Monitoring and reviewing performance (Correct)**
- Taking corrective actions

**Reasoning:** The Check phase evaluates if controls meet objectives.

## 23

Which of the following biometric metrics measures the rate at which authorized users are denied access?

- False Acceptance Rate (FAR)
- **False Rejection Rate (FRR) (Correct)**
- Crossover Error Rate (CER)
- Identity Correlation Rate

**Reasoning:** FRR (Type I) occurs when the system fails to recognize a valid user.

## 24

Which of the following is the best reason to perform an egress filtering on a firewall?

- Prevent external scanning
- **Prevent unauthorized data exfiltration (Correct)**
- Balance ISP load
- Assign dynamic IPs

**Reasoning:** Egress filtering controls traffic leaving the network.

## 25

What does the 'A' in the IAAA model of access control stand for in the context of proving who performed an action?

- Authorization
- Authentication
- **Accountability (Correct)**
- Availability

**Reasoning:** Accountability ensures actions can be uniquely traced back to an individual.

## 26

Which document defines the specific security requirements for a system and serves as the basis for its authorization to operate?

- **System Security Plan (SSP) (Correct)**
- Service Level Agreement (SLA)
- Business Impact Analysis (BIA)
- Acceptable Use Policy (AUP)

**Reasoning:** The SSP describes the controls in place to meet security requirements.

## 27

When an organization decides to outsource its data storage to a cloud provider, which risk management strategy is primarily being used regarding the physical security of the hardware?

- Acceptance
- Avoidance
- **Risk Transference (Correct)**
- Mitigation

**Reasoning:** Moving to the cloud transfers responsibility to the provider.

## 28

Which of the following is a symmetric encryption algorithm?

- RSA
- **AES (Correct)**
- Diffie-Hellman
- ECC

**Reasoning:** Advanced Encryption Standard is a symmetric block cipher.

## 29

What is the primary purpose of an 'Exit Interview' from a security perspective?

- Offer better salary
- **Ensure property return and remind of obligations (Correct)**
- Coworker feedback
- Job placement

**Reasoning:** Exit interviews reinforce legal protection of company data.

## 30

Which type of control is a 'Warning Sign' posted on a fence?

- Preventive

- Detective
- **Deterrent (Correct)**
- Corrective

**Reasoning:** Deterrents aim to discourage potential attackers.

## 31

In the NIST Cybersecurity Framework (CSF), which function is responsible for developing and implementing the appropriate activities to identify the occurrence of a cybersecurity event?

- Identify
- Protect
- **Detect (Correct)**
- Respond

**Reasoning:** Detect is aimed at timely discovery of events.

## 32

What is the primary risk of using 'Single Sign-On' (SSO)?

- Too many passwords
- **Single point of failure/high-value target (Correct)**
- Slow login
- Prevents MFA

**Reasoning:** Compromise of SSO grants access to all authorized systems.

## 33

Which of the following describes a 'Shoulder Surfing' attack?

- Intercepting wireless signals
- **Observing user entering PIN/password (Correct)**
- Phishing email
- Tailgating

**Reasoning:** Shoulder surfing is a visual credential theft technique.

## 34

What is the function of a Security Information and Event Management (SIEM) system?

- Encrypt hard drives
- **Aggregate and correlate log data (Correct)**
- Backup power
- Manage password lifecycle

**Reasoning:** SIEM provides centralized analysis of security alerts.

## 35

Which level of data classification is typically used for information that, if disclosed, would cause 'serious damage' to national security?

- Unclassified
- Confidential

- **Secret (Correct)**
- Top Secret

**Reasoning:** Secret classification corresponds to 'serious damage'.

## 36

What is the primary purpose of a 'Business Impact Analysis' (BIA)?

- Identify vulnerabilities
- **Determine effects of operational disruption (Correct)**
- Calculate ROI
- Assign clearances

**Reasoning:** BIA helps prioritize recovery efforts based on criticality.

## 37

Which of the following is a compensatory control?

- Firewall rule
- **Increasing manual log review due to SIEM outage (Correct)**
- Password policy
- New door lock

**Reasoning:** Compensatory controls are alternative measures used when primary controls are unavailable.

## 38

An attacker uses a list of common passwords to try and gain access to many different user accounts. Which type of attack is this?

- Brute Force
- **Password Spraying (Correct)**
- Birthday
- Dictionary

**Reasoning:** Password spraying targets many accounts with few passwords.

## 39

Which protocol is commonly used for secure web browsing and operates over port 443?

- HTTP
- **HTTPS (Correct)**
- SSH
- FTP

**Reasoning:** HTTPS provides encryption and authentication for web traffic.

## 40

What is the primary objective of 'Need to Know'?

- Mission statement
- **Restrict access to specific job requirements (Correct)**
- Data availability

- Bypass labels

**Reasoning:** Need to know ensures specific data access is limited to necessity.

## 41

Which type of risk is identified as the probability of a threat source exploiting a vulnerability?

- Impact
- **Likelihood (Correct)**
- Threat Agent
- Vulnerability

**Reasoning:** Likelihood describes the chance of a risk manifesting.

## 42

A technician is tasked with destroying hard drives containing highly sensitive data so that the data cannot be recovered even with laboratory equipment. Which method is most effective?

- Formatting
- Deleting
- **Degaussing (Correct)**
- One-pass shredder

**Reasoning:** Degaussing disrupts magnetic data storage permanently.

## 43

Which principle states that an individual should be granted only the minimum permissions necessary to perform their job?

- Need to Know
- **Least Privilege (Correct)**
- Separation of Duties
- Dual Control

**Reasoning:** Least privilege limits the potential damage from a compromised account.

## 44

What is the result of a 'False Negative' in a vulnerability scan?

- Incorrect reported vulnerability
- **Unidentified existing vulnerability (Correct)**
- Scanner crash
- Correct identification

**Reasoning:** False negatives provide a false sense of security.

## 45

Which of the following is a primary benefit of using Attribute-Based Access Control (ABAC)?

- Simple configuration
- **Granular decisions based on context (Correct)**
- Solely group-based
- Cloud incompatible

**Reasoning:** ABAC evaluates user, resource, and environment attributes.

## 46

What is the purpose of 'Salting' a password before hashing it?

- User memory
- **Ensure unique hashes for same passwords (Correct)**
- Encryption recovery
- Authentication speed

**Reasoning:** Salting defeats rainbow table attacks.

## 47

In risk management, what is the 'Recovery Time Objective' (RTO)?

- Max data loss
- **Max targeted duration for restoration (Correct)**
- Notification time
- Backup lifespan

**Reasoning:** RTO focuses on the downtime tolerance.

## 48

Which type of firewall inspects the actual content of the traffic to make filtering decisions?

- Packet Filtering
- Circuit-Level
- **Application-Level Gateway (Proxy) (Correct)**
- Stateful Inspection

**Reasoning:** Application proxies inspect Layer 7 data.

## 49

Which of the following is considered 'Two-Factor Authentication' (2FA)?

- Password and PIN
- **Smart card and fingerprint scan (Correct)**
- Two passwords
- Retinal and voice

**Reasoning:** 2FA requires two different categories of factors.

## 50

What is the primary purpose of a 'Digital Signature'?

- Encryption
- **Integrity, authenticity, and non-repudiation (Correct)**
- Hide IP
- Compression

**Reasoning:** Digital signatures prove origin and message integrity.

## 51

Which of the following describes a 'Logical Honeypot'?

- Locked physical server
- **Fake network service/system for monitoring (Correct)**
- Software trapdoor
- Physical tape vault

**Reasoning:** Logical honeypots are software decoys.

## 52

What is 'Non-repudiation'?

- Availability
- **Proof of delivery/origin (Correct)**
- Steganography
- Password verification

**Reasoning:** Non-repudiation prevents denial of an action.

## 53

Which regulatory standard focuses on the protection of electronic protected health information (ePHI) in the United States?

- PCI-DSS
- **HIPAA (Correct)**
- GDPR
- SOX

**Reasoning:** HIPAA governs US health data privacy.

## 54

What is the 'Principle of Least Privilege' applied to a service account?

- Domain Admin
- **Only specific necessary permissions (Correct)**
- Shared accounts
- Interactive login

**Reasoning:** Limits damage if the application account is compromised.

## 55

In cryptography, what is a 'Collision'?

- Same ciphertext
- **Different inputs, same output hash (Correct)**
- IP conflict
- Handshake interruption

**Reasoning:** Collisions reveal weaknesses in hash algorithms.

## 56

Which of the following is an example of an Administrative Control?

- Biometric scanner
- Account script
- **Mandatory vacation policy (Correct)**
- Firewall rule

**Reasoning:** Administrative controls are management policies.

## 57

What is the primary purpose of 'Defense in Depth'?

- Complexity
- **Multiple layers of protection (Correct)**
- Single vendor
- Perimeter focus

**Reasoning:** Eliminates single points of failure in security.

## 58

Which term describes the process of identifying, prioritizing, and responding to risks?

- **Risk Management (Correct)**
- Risk Assessment
- Risk Avoidance
- Vulnerability Scanning

**Reasoning:** Risk management is the overarching framework.

## 59

What is 'Whitelisting' in the context of application security?

- Forbidden websites
- **Allowing only pre-approved applications (Correct)**
- Admin list
- IP assignment

**Reasoning:** Whitelisting is an 'implicit deny' for software.

## 60

Which of the following is the most important factor in the success of an information security program?

- Expensive firewall
- Technical team
- **Senior Management Support (Correct)**
- Open-source software

**Reasoning:** Support from leadership provides necessary authority and resources.

## 61

An organization is using the NIST SP 800-30 framework for a risk assessment. Which of the following is the first step in this process?

- Likelihood Determination
- **System Characterization (Correct)**
- Control Analysis
- Impact Analysis

**Reasoning:** System characterization defines the scope and components.

## 62

Which of the following is a primary characteristic of the Bell-LaPadula security model?

- No Read Down
- **No Read Up (Simple Security Property) (Correct)**
- No Write Up
- No Read Up (Star Property)

**Reasoning:** Bell-LaPadula focuses on confidentiality/no unauthorized disclosure.

## 63

A security professional is conducting a qualitative risk assessment. Which tool are they most likely to use?

- **Probability and Impact Matrix (Correct)**
- Asset Value calculation formulas
- ALE
- ROSI

**Reasoning:** Qualitative assessments use descriptive scales on matrices.

## 64

Which of the following describes the 'Object' in an access control relationship?

- Requester
- **Resource being requested (Correct)**
- Decision rule
- Server location

**Reasoning:** Objects are passive resources containing information.

## 65

In a Discretionary Access Control (DAC) model, who has the authority to grant access to a specific file?

- Security Admin
- **Data Owner (Correct)**
- Auditor
- CIO

**Reasoning:** DAC empowers the owner to decide permissions.

## 66

What is the primary risk of 'Provisioning' new user accounts without a formal process?

- Hardware costs
- **Excessive privileges/ghost accounts (Correct)**
- Forgotten usernames
- Network speed

**Reasoning:** Informal provisioning leads to unmanaged access levels.

## 67

Which type of risk is left over after all possible controls have been implemented?

- Inherent Risk
- **Residual Risk (Correct)**
- Control Risk
- Transferred Risk

**Reasoning:** Residual risk is the leftover risk organizations accept.

## 68

When monitoring for insider threats, which of the following is most likely to indicate a problem?

- Normal login
- **Anomalous large volume data access (Correct)**
- Vacation approval
- System update

**Reasoning:** Deviations from baseline behavior indicate threats.

## 69

Which of the following protocols is used to provide centralized Authentication, Authorization, and Accounting (AAA) for remote dial-in users?

- **RADIUS (Correct)**
- SNMP
- SMTP
- ICMP

**Reasoning:** RADIUS is the industry standard for AAA management.

## 70

An organization classifies its data as 'Public,' 'Sensitive,' and 'Confidential.' What kind of classification scheme is this?

- Military
- **Private Sector/Commercial (Correct)**
- Mandatory
- Discretionary

**Reasoning:** Commercial labels reflect business impact.

## 71

Which of the following is the most significant disadvantage of using biometric authentication?

- Forgetful users
- **Unchangeable if compromised (Correct)**
- Expense
- Processing speed

**Reasoning:** Physical traits cannot be 'reset' like passwords.

## 72

Which risk management framework uses a 'three-phased' approach focusing on operational resilience and security?

- NIST RMF
- **OCTAVE (Correct)**
- ISO 27001
- COBIT

**Reasoning:** OCTAVE focuses on strategic assessment and planning.

## 73

A system generates an alert every time a user logs in from a new device. This is an example of which security concept?

- Integrity Checking
- **Anomaly Detection (Correct)**
- Access Revocation
- Data Masking

**Reasoning:** Identifies patterns that deviate from norms.

## 74

Which of the following describes 'Least Privilege' as it applies to an administrator's account?

- Privileged for all tasks
- **Separate non-privileged account for daily activities (Correct)**
- Full control always
- No password expiration

**Reasoning:** Limits the attack surface of powerful accounts.

## 75

In the context of the NIST Risk Management Framework, which step involves determining the impact of a system failure on the organization's mission?

- **Categorize Information System (Correct)**
- Select Controls
- Assess Controls
- Authorize

**Reasoning:** Categorization (Step 2) identifies impact of loss.

## 76

What is the main purpose of a vulnerability scanner?

- Exploit weaknesses
- **Identify known weaknesses/missing patches (Correct)**
- Network encryption
- Traffic filter

**Reasoning:** Scanners compare configurations against databases of known flaws.

## 77

Which of the following is an example of a 'Detective' physical security control?

- Padlock
- **Motion-activated camera recording (Correct)**
- Policy manual
- Deterrent sign

**Reasoning:** Detective controls identify an occurring or past event.

## 78

What is the primary objective of an 'Identity Federation'?

- Same password globally
- **Single credentials for cross-domain access (Correct)**
- Encrypt identities
- Centralized database

**Reasoning:** Federation establishes trust between domains.

## 79

In a risk assessment, a 'Threat' is best defined as:

- System weakness
- **Potential cause of unwanted incident (Correct)**
- Asset value
- Likelihood

**Reasoning:** Threats have potential to adversely impact operations.

## 80

Which of the following is the most effective way to ensure that only authorized users can access a secure server room?

- Warning sign
- **Keycard reader and biometric (dual-factor) (Correct)**
- Unlocked/guards
- Key lock

**Reasoning:** Multi-factor physical control is superior.

## 81

An administrator discovers that a user has been 'elevating' their own permissions by exploiting a flaw in a local application. What is this called?

- **Privilege Escalation (Correct)**
- Social Engineering
- SQL Injection
- DoS

**Reasoning:** Exploiting bugs to gain higher access levels.

## 82

Which component of an Access Control System is responsible for making the decision to allow or deny a request?

- Policy Enforcement Point
- **Policy Decision Point (PDP) (Correct)**
- Policy Information Point
- UI

**Reasoning:** PDP evaluates requests against policies.

## 83

A company requires employees to take one full week of vacation every year during which they cannot access company systems. What is the primary security goal of this policy?

- Electricity costs
- Morale
- **Detect fraudulent activities (Correct)**
- Patching time

**Reasoning:** Mandatory vacations help uncover internal fraud.

## 84

Which of the following is the best example of 'Data at Rest'?

- Email in transit
- **File on SAN (Correct)**
- Password processing
- Streaming video

**Reasoning:** Inactive data stored on digital media.

## 85

What is the primary advantage of 'Role-Based Access Control' (RBAC) over 'Discretionary Access Control' (DAC) in a large organization?

- Friend sharing
- **Reduced overhead/scalable management (Correct)**
- CEO full access
- Cheaper

**Reasoning:** Linked permissions to job functions scales better.

## 86

Which of the following is a 'Management' (Administrative) risk response?

- Firewall installation
- **Security Awareness training (Correct)**
- Biometric locks
- AES encryption

**Reasoning:** Administrative controls focus on policy and behavior.

## 87

What is 'Account Harvesting'?

- Deleting old accounts
- **Collecting valid usernames for future attacks (Correct)**
- New employee provisioning
- Password resets

**Reasoning:** Reconnaissance step to build target lists.

## 88

Which term describes a control that is designed to restore a system to its normal state after a security incident?

- Preventive
- Detective
- **Corrective (Correct)**
- Deterrent

**Reasoning:** Corrective controls fix damage and return system to function.

## 89

What is the main difference between 'Identification' and 'Authentication'?

- Same thing
- **Claiming vs Proving identity (Correct)**
- Biometric vs Password
- Firewall vs Database

**Reasoning:** Username = identification; Password = authentication.

## 90

In a Biba Integrity Model, what does 'No Write Up' (Simple Integrity Axiom) mean?

- No Read Down
- **No Write Up to higher integrity level (Correct)**
- No self-deletion
- No view other files

**Reasoning:** Prevents low-integrity data from contaminating high-integrity levels.

## 91

Which of the following is a primary goal of 'Asset Management'?

- Fastest computers
- **Know what/where assets are and responsibility (Correct)**
- eBay sales
- Cloud migration

**Reasoning:** Protection requires visibility and inventory.

## 92

Which risk assessment method is purely based on numeric values and monetary calculations?

- Qualitative
- **Quantitative (Correct)**
- Semi-qualitative
- Delphi

**Reasoning:** Quantitative analysis uses mathematical formulas for dollar amounts.

## 93

Which of the following is a drawback of using a 'Single Sign-On' (SSO) solution?

- 20 passwords
- **Single point of failure (Correct)**
- Longer login
- Prevents MFA

**Reasoning:** System outages lock users out of everything.

## 94

An administrator uses a 'Checklist' to ensure that every new server is hardened the same way. This is an example of what?

- **Security Baseline (Correct)**
- Risk Appetite
- False Positive
- Honey Pot

**Reasoning:** Baselines ensure consistent standards.

## 95

What is the 'Crossover Error Rate' (CER) in biometrics?

- Power outage
- **Point where FAR and FRR are equal (Correct)**
- User refusal
- Scan speed

**Reasoning:** CER measures overall accuracy.

## 96

What is the primary goal of 'Change Management'?

- Prevent changes
- **Controlled, evaluated implementation (Correct)**
- Direct dev access
- Replace humans

**Reasoning:** structured process to maintain stability.

## 97

Which of the following is an example of an 'Internal' threat?

- Foreign hacker
- **Disgruntled employee deleting files (Correct)**
- Hurricane
- Stranger phishing

**Reasoning:** Internal threats come from authorized persons.

## 98

In the NIST Cybersecurity Framework, which function is responsible for ensuring that the organization can restore its capabilities after an incident?

- Identify
- Protect
- Detect
- **Recover (Correct)**

**Reasoning:** Recover focuses on resilience and restoration.

## 99

Which term describes the process of reviewing user permissions on a regular basis to ensure they are still appropriate?

- Access Provisioning
- **User Access Review (Correct)**
- SSO
- Brute Force

**Reasoning:** Periodic reviews prevent privilege creep.

## 100

What is the main purpose of an 'Intrusion Detection System' (IDS)?

- Block traffic
- **Monitor activities and report violations (Correct)**
- File encryption
- Speed caching

**Reasoning:** IDS is a detective tool for alerts.

## 101

Which of the following describes 'Availability' in the CIA Triad?

- Authorized viewing
- No tampering
- **Accessible when needed (Correct)**
- Non-repudiation

**Reasoning:** Availability focuses on uptime and reliability.

## 102

Which type of control is 'Security Awareness Training' for employees?

- Technical
- **Administrative (Correct)**
- Physical
- Detective

**Reasoning:** Training is a behavior management policy.

## 103

A user's account is locked after three failed login attempts. Which security goal does this serve?

- **Confidentiality (Correct)**
- Availability
- Integrity
- Non-repudiation

**Reasoning:** Prevents unauthorized access via password cracking.

## 104

What is the 'Annualized Rate of Occurrence' (ARO) for a risk that happens once every five years?

- 5.0
- **0.2 (Correct)**
- 1.0
- 0.5

**Reasoning:** ARO frequency is 1/5 per year.

## 105

Which of the following describes a 'Type II' biometric error?

- False Rejection
- **False Acceptance (Correct)**
- CER
- Timeout

**Reasoning:** unauthorized user granted access.

## 106

What is the primary benefit of using a 'Proxy Server'?

- Hard drive encryption
- **Acting as intermediary/filtering content (Correct)**
- Power switches
- Backup emails

**Reasoning:** Proxies provide anonymity and outbound control.

## 107

Which data classification level is highest in a typical commercial environment?

- Sensitive
- **Confidential (Proprietary) (Correct)**
- Public
- Unclassified

**Reasoning:** Confidential labels are for trade secrets/core IP.

## 108

Which of the following is an example of 'Dual Control'?

- Password and PIN
- **Two people for one task simultaneously (Correct)**
- Two servers
- Dual power

**Reasoning:** Dual control prevents solo high-risk actions.

## 109

What is the role of an 'Authorizing Official' (AO) in risk management?

- Code writing
- Technical scan
- **Assume risk responsibility (Correct)**
- Financial audit

**Reasoning:** The AO sign-off enables system operation.

## 110

Which of the following is the most effective way to prevent 'Tailgating'?

- Signage
- **Mantrap or turnstile (Correct)**
- Employee politeness
- Door color

**Reasoning:** Mantraps allow only one authorized person at a time.

## 111

Which of the following is the most important consideration when choosing a data destruction method for magnetic media?

- Physical size
- **Sensitivity of data (Correct)**
- Casing color
- Hardware brand

**Reasoning:** Destruction must match risk levels.

## 112

In asymmetric cryptography, which key is used to create a digital signature that provides non-repudiation?

- Sender public key
- **Sender private key (Correct)**
- Recipient public key
- Session key

**Reasoning:** Private key uniquely proves origin.

## 113

Which of the following describes a 'False Acceptance' (Type II Error) in a biometric system?

- Authorized user denied
- **Unauthorized user granted access (Correct)**
- System crash
- Template encryption

**Reasoning:** Type II error is failing to detect an intruder.

## 114

An organization wants to verify that their cloud provider is meeting specific security and privacy control requirements. Which SOC report is most appropriate for this detailed, 'points-in-time' review?

- SOC 1 Type I
- **SOC 2 Type II (Correct)**
- SOC 3
- PCI-DSS

**Reasoning:** SOC 2 Type II audits control effectiveness over time.

## 115

Which phase of the data lifecycle involves the creation or acquisition of new data elements?

- Store
- **Create (Correct)**
- Archive
- Destroy

**Reasoning:** Create is the initial acquisition phase.

## 116

What is the primary purpose of 'Key Escrow'?

- Hide from law
- **Backup for recovery (Correct)**
- Speed
- Password change

**Reasoning:** Escrow ensures access if key holder is unavailable.

## 117

In a commercial data classification scheme, which label is typically applied to information that is not sensitive and can be seen by anyone?

- Private
- **Public (Correct)**
- Secret
- Proprietary

**Reasoning:** Public data carries no confidentiality risk.

## 118

Which of the following represents a 'Logical' (Technical) access control?

- Security guard
- **Firewall rules (Correct)**
- Background check
- Perimeter fence

**Reasoning:** Enforced by hardware/software mechanisms.

## 119

What is the primary difference between 'Steganography' and 'Encryption'?

- Encryption hides existence
- **Steganography hides existence, encryption scrambles content (Correct)**
- Speed
- Key requirement

**Reasoning:** Steganography is 'hiding in plain sight'.

## 120

A security professional uses a tool to capture and analyze packets as they travel across the network. What is this tool called?

- Vulnerability scanner
- **Protocol Analyzer (Sniffer) (Correct)**
- Honeypot
- Port scanner

**Reasoning:** Decodes network traffic to diagnose issues.

## 121

Which aspect of the IAAA model ensures that a user's identity is verified before access is granted?

- Identification
- **Authentication (Correct)**
- Authorization
- Accountability

**Reasoning:** Authentication is the proof stage.

## 122

What is the primary goal of 'Data Masking'?

- Permanent deletion
- **Protect sensitive data with fictional realistic data (Correct)**
- Compression
- Encryption

**Reasoning:** Obfuscates results while maintaining usability.

## 123

Which of the following is the most significant risk associated with 'Bring Your Own Device' (BYOD) policies?

- Hardware costs
- **Mixing personal and corporate data (Correct)**
- Carrying devices
- Battery life

**Reasoning:** Unmanaged co-mingled data is difficult to secure.

## 124

In the context of access control, what is 'Privilege Creep'?

- Slow computer
- **Accumulation of rights across different roles (Correct)**
- Slow network attack
- Budget increase

**Reasoning:** Old permissions aren't removed when jobs change.

## 125

Which security principle is violated if an administrator uses the same password for both their personal email and their root server account?

- Least Privilege
- Separation of Duties
- **Defense in Depth (Correct)**
- Availability

**Reasoning:** Password reuse creates single points of failure across layers.